

# PROJET FINAL

## Sécurité des bases de données

### OPÉRATION BLACKVAULT

Concevoir, sécuriser et piéger une base de données de gestion de secrets classifiés

Groupes de 4 à 5 étudiants | Durée : 3 mois | Soutenance : 30 minutes

Hakim Loumi - Kyrion-CS

Ecole 2600

2025-2026

# 1. Contexte et mise en situation

Vous êtes une équipe de **Database Security Engineers** recrutés par une organisation de très haut niveau (agence de renseignement, état-major militaire, banque centrale, laboratoire pharmaceutique classifié, ou tout autre organisme que vous choisirez).

Votre mission : concevoir de A à Z la base de données qui stockera les secrets les plus sensibles de cette organisation. Cette base doit être non seulement sécurisée, mais aussi capable de piéger un attaquant qui parviendrait à y pénétrer.

Vous êtes libres de choisir :

- Le type d'organisation (défense, finance, santé, spatial, nucléaire, diplomatie...)
- Le SGBD (Oracle, PostgreSQL, MySQL, SQL Server, MongoDB, ou tout autre)
- Le sujet exact de la base (tant qu'il concerne la gestion de secrets de très haut niveau)

**Exemples de sujets possibles (non exhaustifs) :**

- Base de gestion des agents infiltrés d'une agence de renseignement (identités, couvertures, missions, contacts, exfiltrations)
- Base de gestion des codes nucléaires et des procédures de lancement (sites, habilitations, protocoles, rotations de clés)
- Base de gestion des brevets classifiés d'un laboratoire pharmaceutique (molécules, essais cliniques, résultats secrets)
- Base de gestion des négociations diplomatiques secrètes (participants, positions, concessions, accords en cours)
- Base de gestion des vulnérabilités 0-day d'une Red Team nationale (CVE non publiées, exploits, cibles)
- Base de gestion des témoins protégés d'un programme de protection (identités réelles, nouvelles identités, localisations)

**Le sujet doit justifier un niveau de classification élevé.**

**Si la fuite de votre base ne ferait pas la une du journal → le sujet n'est pas assez sensible.**

## 2. Livrables attendus

Vous devez fournir 4 livrables obligatoires :

### Livable A - Modélisation sécurisée

Un document de modélisation complet contenant :

- Le cahier des charges de l'organisation fictive (1-2 pages)
- Le MLD (Modèle Logique de Données) avec Looping
- La classification de CHAQUE table selon Bell-LaPadula (Public / Confidentiel / Secret / Top Secret)
- La classification de CHAQUE table selon Biba (Haute / Basse intégrité)
- La matrice d'accès par profil utilisateur (qui voit quoi, qui modifie quoi)
- Le schéma d'architecture (DFD orienté sécurité, Trust Boundaries, chemins d'attaque identifiés)

#### Contraintes de modélisation :

- Minimum 20 tables (dont au moins une table de Staging, une table de log des connexions et une table de log des accès aux tables sensibles)
- Au moins 3 niveaux de classification de données dans le schéma
- Au moins 4 profils utilisateurs avec des droits différents
- Les relations, contraintes d'intégrité, index et partitions doivent être justifiés

### Livable B - Implémentation technique

Les scripts SQL/NoSQL exécutables contenant :

#### B1 — Structure et données

- Scripts de création du schéma complet (DDL)
- Jeu de données réaliste (minimum 1000 lignes dans les tables principales)
- Au moins 5 procédures stockées (logique métier sécurisée, validation, promotion staging → prod)
- Au moins 3 fonctions (hachage, vérification, calcul)
- Au moins 3 triggers (audit, contrôle, blocage d'opérations interdites)

#### B2 — Sécurité classique

- Création des utilisateurs/rôles avec moindre privilège (RBAC)
- Profile de mot de passe (complexité, expiration, verrouillage)
- Chiffrement : au minimum le réseau (TLS/SQLNET) + au moins une mesure At-Rest (TDE, chiffrement colonne, ou pgcrypto)
- Vues masquées pour les données sensibles
- Audit activé sur les tables critiques

## B3 — Deception

C'est ici que vous montrez que vous avez compris le cours.

Vous devez implémenter au minimum 4 des 7 techniques suivantes :

| # | Technique                       | Description                                                                              | Obligatoire ? |
|---|---------------------------------|------------------------------------------------------------------------------------------|---------------|
| 1 | <b>Honeytokens</b>              | Faux enregistrements dans les tables réelles + Fine-Grained Auditing ou trigger d'alerte | <b>OUI</b>    |
| 2 | <b>Tables leurres</b>           | Tables aux noms attractifs (CREDENTIALS, PASSWORDS, KEYS) avec audit immédiat            | <b>OUI</b>    |
| 3 | <b>VPD ou RLS</b>               | Filtrage automatique par utilisateur (Oracle VPD, PostgreSQL RLS, ou équivalent)         | <b>OUI</b>    |
| 4 | <b>Synonymes/Vues Deception</b> | Synonymes redirigeant vers des vues leurres ou masquées selon le profil                  | <b>OUI</b>    |
| 5 | <b>Bruit statistique</b>        | Faux enregistrements mêlés aux vrais avec marqueur invisible                             | NON           |
| 6 | <b>Watermarking</b>             | Export personnalisé par utilisateur avec micro-variations traçables                      | NON           |
| 7 | <b>Polyinstanciation</b>        | Même requête, résultats différents selon l'utilisateur (vraies vs fausses valeurs)       | NON           |

Les 4 premières techniques sont obligatoires. Vous devez en ajouter au moins une parmi les 3 restantes. Plus vous en implémentez, plus la note sera élevée.

## Livrable C — Rapport de sécurité

Un document de 10-15 pages contenant :

- Analyse STRIDE de votre architecture (chaque composant passé au crible des 6 menaces)
- Identification de minimum 2 chemins d'attaque sur votre propre système
- Pour chaque chemin : la défense mise en place et la technique de Deception qui le piège
- Analyse des limites : quelles attaques votre système ne couvre-t-il PAS ?
- Conformité réglementaire : comment votre design respecte le RGPD, NIS2, ou la réglementation applicable à votre domaine

## Livrable D — Soutenance

Présentation orale de 25 minutes devant le jury + 5 minutes de Q/R.

**La soutenance doit être professionnelle.**

**Voici les critères de qualité attendus :**

### **Format de la présentation**

- Slides de qualité professionnelle (pas de template PowerPoint par défaut, pas de mur de texte, des schémas)
- Charte graphique cohérente du début à la fin
- Chaque slide a un message clé visible en 3 secondes
- Les diagrammes d'architecture, DFD, schémas de Deception sont VISUELS, pas du texte
- Maximum 20-25 slides (1 slide par minute)

### **Prise de parole**

- TOUS les membres du groupe prennent la parole (répartition équitable)
- Pas de lecture de slides — vous connaissez votre sujet
- Regarder le jury, pas l'écran
- Enchaînements fluides entre les speakers (pas de "bon bah, à toi maintenant !")
- Respecter STRICTEMENT les 25 minutes (chronomètre)

### **Contenu de la soutenance**

- Introduction : le contexte, l'organisation fictive, pourquoi ce sujet (2 min)
- Modélisation : MCD/MLD, classification Bell-LaPadula/Biba, architecture (3-5 min)
- Sécurité classique : RBAC, chiffrement, audit — en montrant le code qui tourne (3 min)
- Deception : démonstration LIVE des pièges (7-9 min)
- Attaque simulée : un membre joue l'attaquant, les autres montrent les alertes (3-5 min)
- Limites et perspectives : honnêteté sur ce qui manque (2-3 min)
- Conclusion (1 min)

**La démonstration LIVE de la Deception est le moment clé de la soutenance.**

**Le jury doit voir un attaquant tomber dans un piège en temps réel.**

### 3. Barème de notation

| Critère                              | Points     | Détail                                                                                                         |
|--------------------------------------|------------|----------------------------------------------------------------------------------------------------------------|
| Modélisation sécurisée (Livable A)   | /3         | MCD/MLD/MPD, classification Bell-LaPadula & Biba, matrice d'accès, DFD sécurité, qualité du cahier des charges |
| Implémentation technique (Livable B) | /3         | Scripts fonctionnels, 20+ tables, procédures/fonctions/triggers, RBAC, chiffrement, audit, qualité du code SQL |
| Techniques de Deception (B3)         | /4         | 4 techniques minimum, originalité, cohérence avec le scénario, démonstration fonctionnelle                     |
| Rapport de sécurité (Livable C)      | /2         | STRIDE, chemins d'attaque, limites, comparaison SGBD, conformité réglementaire                                 |
| Soutenance (Livable D)               | /8         | Qualité des slides, prise de parole, démo LIVE, respect du timing, réponses aux questions                      |
| <b>TOTAL</b>                         | <b>/20</b> |                                                                                                                |

#### Bonus (jusqu'à +3 points)

- +1 : implémenter les 7 techniques de Deception (pas seulement 4)
- +1 : réaliser un vrai Red Team / Blue Team pendant la soutenance (un binôme attaque, l'autre défend)
- +1 : qualité exceptionnelle de la présentation (slides dignes d'un cabinet de conseil)

#### Malus (jusqu'à -5 points)

- -1 : slides médiocres (template par défaut, murs de texte, pas de schémas)
- -1 : un ou plusieurs membres du groupe ne prennent pas la parole ou dépassement du temps
- -1 : code non fonctionnel le jour de la soutenance
- -2 : pas de démonstration LIVE (uniquement des screenshots)

## 4. Planning et jalons

| Jalon      | Délai      | Livrable attendu                                                                                 |
|------------|------------|--------------------------------------------------------------------------------------------------|
| J1         | Semaine 1  | Constitution des groupes + choix du sujet (mail au formateur avec : membres, sujet, SGBD choisi) |
| J2         | Semaine 4  | Cahier des charges + MLD validé par le formateur (review de 10 min par groupe en cours)          |
| J3         | Semaine 8  | Point d'avancement : scripts de création + au moins 2 techniques de Deception fonctionnelles     |
| J4         | Semaine 11 | Remise de TOUS les livrables (A + B + C) par email/dépôt avant la soutenance                     |
| SOUTENANCE | Semaine 12 | Présentation orale de 25 minutes + démonstration LIVE + 5 minutes de Q/R                         |

**Le jalon J2 (validation MCD) est un point de non-retour.**

**Si votre MCD n'est pas validé, vous ne pouvez pas avancer sur l'implémentation. Ne le négligez pas.**

Le formateur est disponible par email pour répondre à vos questions techniques entre les séances. Mais il ne fera pas le travail à votre place.

## 5. Règles et intégrité

Ce projet est un travail de GROUPE.

Voici les règles :

- Chaque membre doit contribuer de manière équitable. Un document de répartition des tâches sera joint au rapport.
- Le plagiat entre groupes est interdit. Si deux groupes rendent des scripts identiques, les deux groupes auront 0.
- L'utilisation d'une IA (ChatGPT, Claude, Copilot) est autorisée comme outil d'assistance, mais vous devez comprendre et pouvoir expliquer chaque ligne de code que vous rendez. Si vous ne savez pas expliquer votre propre code pendant la soutenance, c'est un problème.
- Le SGBD est libre, mais vous devez le maîtriser. Ne choisissez pas MongoDB si personne dans le groupe ne connaît MongoDB.
- La base doit être fonctionnelle et démontrable le jour de la soutenance. Prévoyez un environnement de backup (Docker, VM, cloud) au cas où votre machine principale tombe.

## 6. Conseil du formateur

*Ce projet n'est pas un exercice académique. C'est une simulation de ce que vous ferez en entreprise. Le client (ici, l'organisation fictive) vous confie ses secrets les plus sensibles. Si votre base est compromise, des gens meurent, des entreprises font faillite, des États sont déstabilisés.*

*La différence entre un bon projet et un projet exceptionnel, c'est la Deception. N'importe qui peut mettre un mot de passe sur une base. Très peu savent piéger l'attaquant qui a déjà franchi toutes les défenses. C'est là que vous montrez votre valeur.*

***Amusez-vous. Soyez créatifs. Surprenez-moi.***